ENGINEERING CASE STUDY

Secure Healthcare Data-Access Portal Platform

A multi-tenant, PHI-grade web portal platform — two Angular portals over a private, authorizer-gated API, a standards-based FHIR clinical-data explorer, claim-based RBAC, and cross-cloud delivery as code.

Angular · OIDC / PKCE · Claim-based RBAC · Private API Gateway · Lambda authorizer · HL7 FHIR R4 · HITRUST-aligned · Multi-tenant · AWS SAM · CloudFront + WAF · CloudFormation IaC · Cross-cloud CI/CD · Shared design-system · Okta auth library

CHALLENGE

Expose regulated health data to many audiences — without compromising trust

A healthcare-data organization needed to serve **protected health information (PHI)** — member records and clinical data — to internal staff, providers, and third-party developers through the web. The bar for security, compliance, and standards conformance was absolute, and the same platform had to scale from one internal console to a public developer ecosystem.

Different audiences, one data estate

Internal staff needed an admin console; external partners needed a self-service portal to register apps and test APIs against a sandbox — without maintaining divergent codebases.

PHI raises the bar on everything

Every screen and API call touches regulated data. Access had to be strongly authenticated, finely authorized per user and per tenant, auditable end-to-end, and the API itself unreachable from the public internet.

Clinical data must speak a standard

Consumers expected **HL7 FHIR** resources — patients, conditions, encounters, medications, labs, procedures, care plans — not a bespoke schema.

Many environments & tenants, one artifact; governed delivery

The app had to run across dev / QA / UAT / production — split across separate cloud accounts and multiple tenants — ideally from one immutable build, with infrastructure and releases codified and promoted through approval gates.

SOLUTION

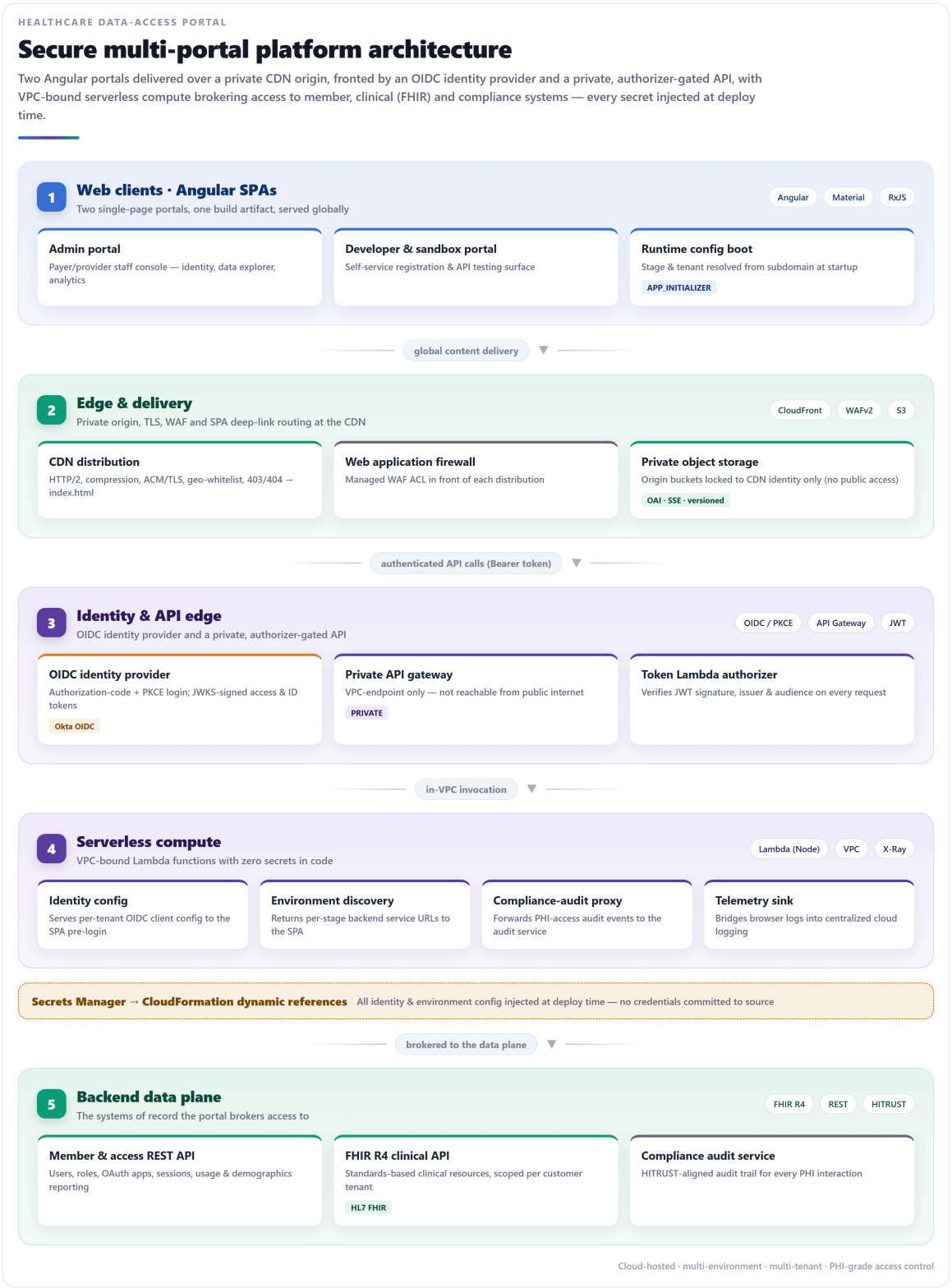
Two portals over a shared foundation — secure, standards-based, delivered as code

A two-portal platform engineered so that security, multi-tenancy, and repeatable delivery are structural rather than bolted on.

- ✓ **One build, every environment.** A single immutable Angular artifact resolves its stage, tenant, backend URLs, and identity config **at runtime from the request subdomain** — so it promotes unchanged from dev to production, and sandbox vs. production is a runtime distinction.
- ✓ **OIDC + PKCE with claim-based RBAC.** A fine-grained permission claim in the signed token drives route guards and menu rendering; the UI only shows what a user is authorized to use.
- ✓ **Private, authorizer-gated API.** The API gateway is reachable only through an in-VPC endpoint; a token Lambda authorizer independently re-verifies every JWT server-side — client checks are never trusted alone.
- ✓ **Standards-based FHIR explorer.** Patient search and profile open onto **15 HL7 FHIR R4 resource types**, paged and searchable, every query scoped to the signed-in tenant.
- ✓ **Self-service admin & analytics.** Full RBAC, OAuth client-app registration, plus API-usage and member-demographics dashboard suites on a reusable filter-and-chart pattern.
- ✓ **Delivered as code.** Reusable nested-stack IaC provisions the estate; a cross-cloud pipeline builds once and promotes through gated environments; shared Angular design-system + auth libraries give both portals one maintained foundation.

ARCHITECTURE

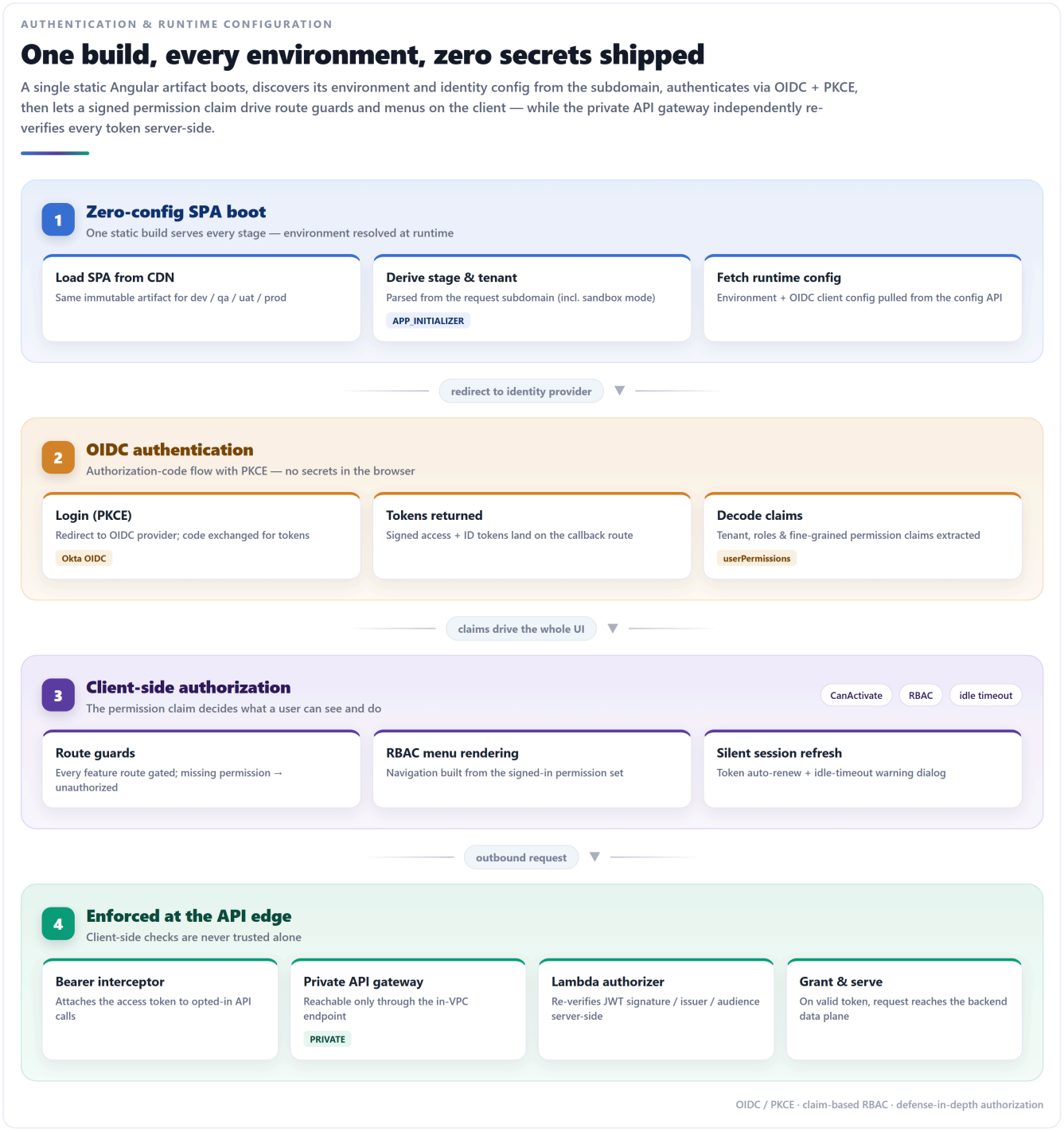
Secure multi-portal platform architecture



Two Angular portals over a private CDN origin, an OIDC identity provider, a private authorizer-gated API, VPC-bound serverless compute, and the backend data plane.

ARCHITECTURE

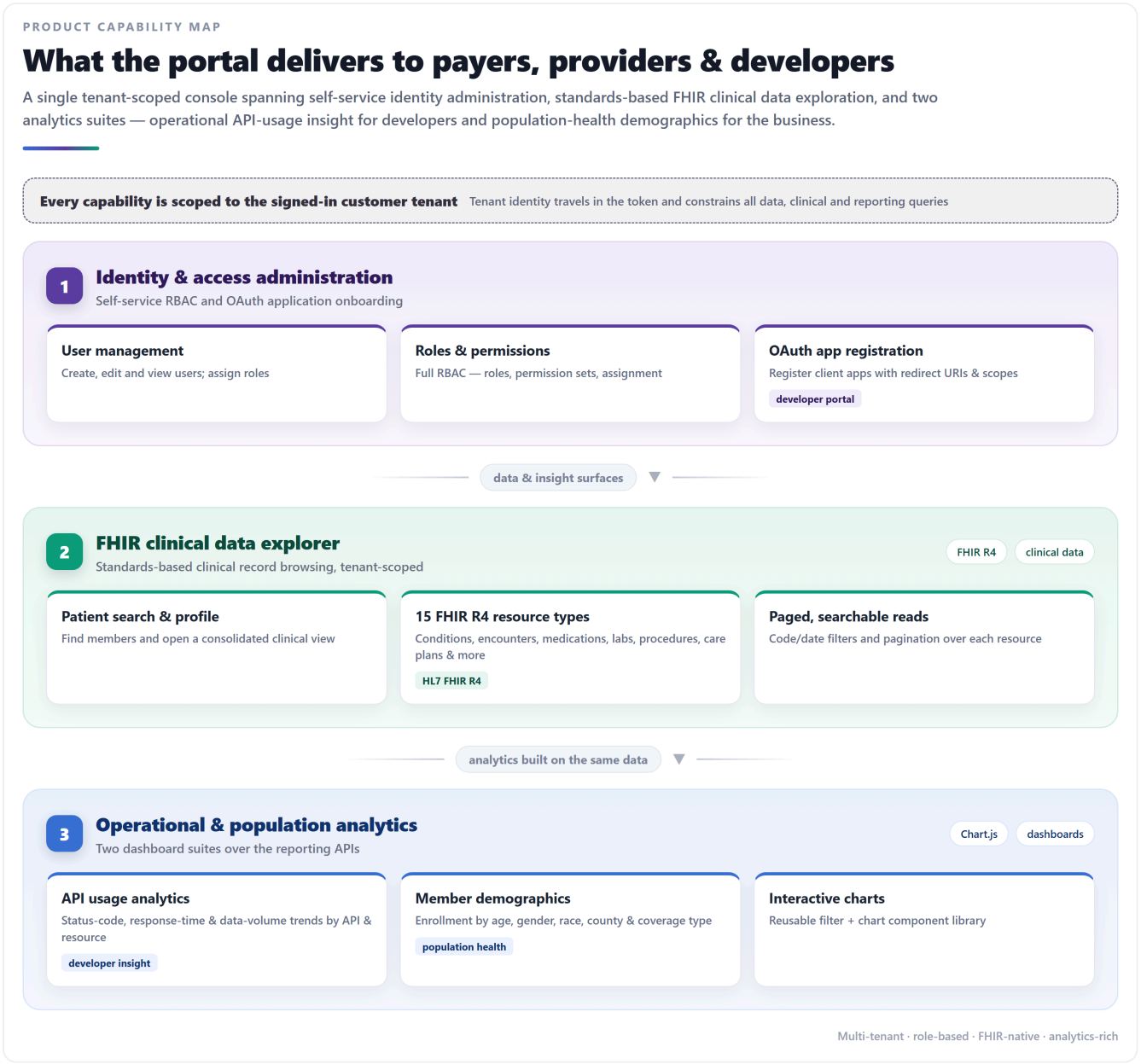
Authentication & runtime configuration



One static build boots, resolves environment and identity from the subdomain, authenticates via OIDC + PKCE, then RBAC-gates the client — while the private API re-verifies every token.

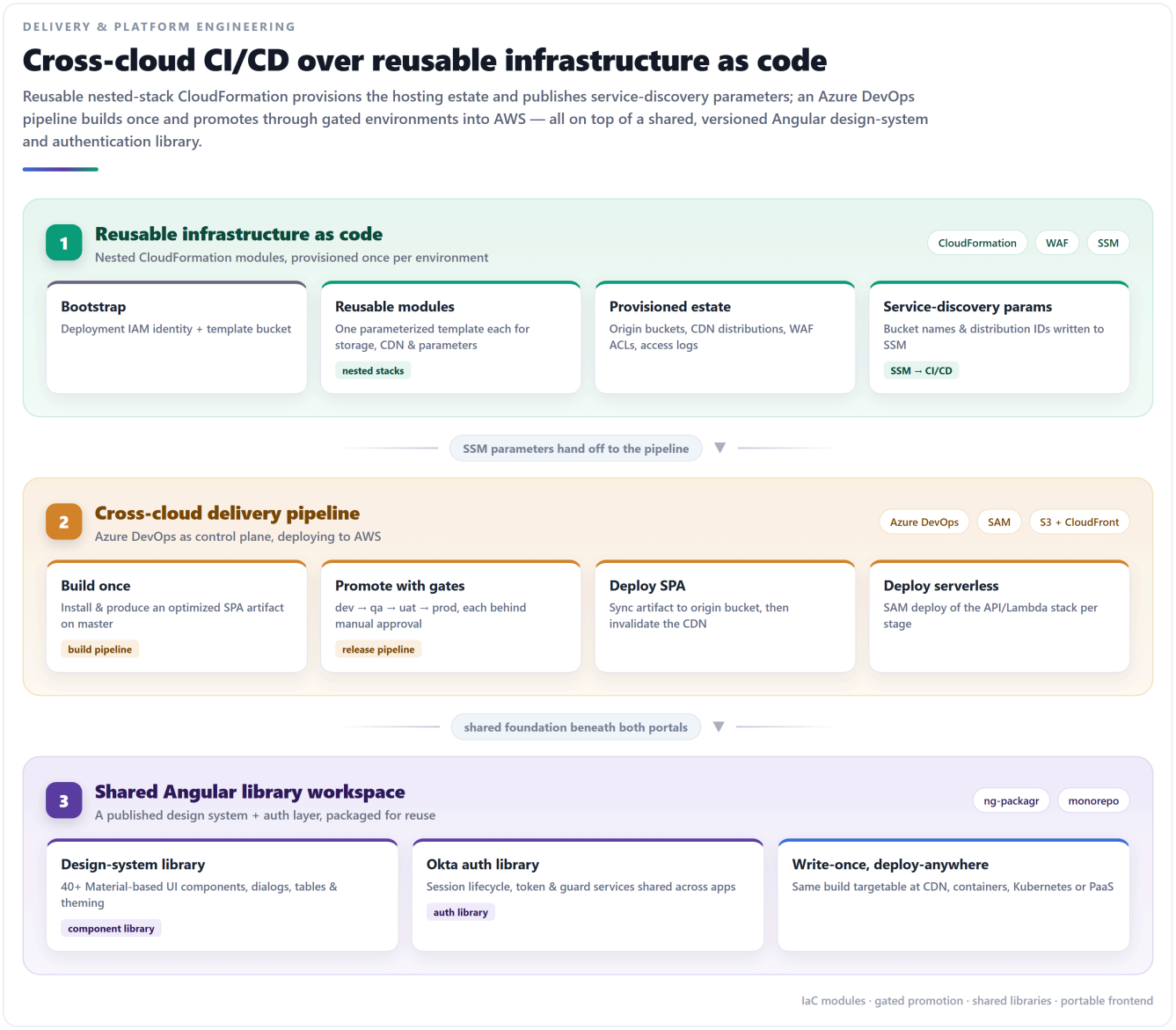
CAPABILITIES

Product capability map



A single tenant-scoped console: identity & access administration, a FHIR R4 clinical-data explorer, and two analytics suites.

Delivery & platform engineering



Reusable nested-stack infrastructure-as-code and a cross-cloud build-once / promote-through-gates pipeline, over shared Angular design-system and auth libraries.

RESULT

A secure, compliant, multi-tenant portal platform — and a reusable foundation

2 portals, 1 build

Admin + developer/sandbox portals from a single runtime-configured artifact

15 FHIR R4

Clinical resource types in a tenant-scoped, standards-based explorer

Private by default

VPC-only API, private CDN origins, secrets injected at deploy time

4 gated stages

dev → QA → UAT → prod, promoted across separate cloud accounts

Defense-in-depth by construction. OIDC + PKCE authentication, a signed permission claim driving client-side RBAC, and an independent server-side Lambda authorizer over a private API gateway mean PHI is never guarded by the client alone. HITRUST-aligned audit forwarding and X-Ray tracing keep behavior traceable.

Built to scale and to reuse. A versioned design-system library and a companion authentication library are packaged and consumed across applications, and the optimized frontend build is targetable at CDN, container, Kubernetes, or PaaS — so the platform can grow from one internal console to a public developer ecosystem without rework, on a foundation reusable across products.

